

Complete Guide to Cookies for SDE-1 Interviews

1. What is HTTP?

HTTP (HyperText Transfer Protocol) is a stateless request-response protocol used between client and server. Stateless means the server does not remember previous requests.

2. Why Cookies Are Needed?

Since HTTP is stateless, cookies help maintain state (like login sessions) between requests.

3. What Are Cookies?

Cookies are small pieces of data stored in the browser. They are sent automatically with every HTTP request to the same domain.

4. How Login Works Using Cookies?

1. User logs in.
2. Server verifies credentials.
3. Server creates session ID.
4. Server sends Set-Cookie header.
5. Browser stores cookie.
6. Browser sends cookie in future requests.
7. Server validates session.

5. Important Cookie Attributes

HttpOnly: Prevents JavaScript access.

Secure: Sent only over HTTPS.

SameSite: Controls cross-site sending.

Expires/Max-Age: Expiry time.

Domain & Path: Scope control.

6. What is Secure?

The Secure attribute ensures cookies are only sent over HTTPS, preventing interception over insecure networks.

7. What is HttpOnly?

Prevents JavaScript from accessing cookies via `document.cookie`. Protects against XSS attacks.

8. What is SameSite?

SameSite controls whether cookies are sent with cross-site requests.

Strict: Only same-site.

Lax: Allows top-level navigation.

None: Allows cross-site but requires Secure.

9. XSS (Cross-Site Scripting)

XSS happens when attacker injects malicious JavaScript. It can steal cookies using `document.cookie` unless HttpOnly is enabled.

10. CSRF (Cross-Site Request Forgery)

CSRF tricks a logged-in user into making unintended requests. Since cookies are auto-sent, attackers can exploit this.

Prevention: SameSite + CSRF tokens.

11. Session-Based Authentication

Server stores session data. Client stores session ID in cookie. Requires server-side storage like DB or Redis.

12. JWT Authentication

JWT contains user data inside token. Server verifies signature without storing session. Stateless and scales better in distributed systems.

13. Cookies vs LocalStorage

Cookies: 4KB, auto-sent with requests.

LocalStorage: Larger size, not auto-sent.

14. Security Best Practices

Use HttpOnly.

Use Secure.

Use SameSite=Lax or Strict.

Implement CSRF tokens.

Use HTTPS everywhere.

15. Interview-Ready Answers

Explain HTTP is stateless.

Explain how cookies maintain sessions.

Explain difference between session and JWT.

Explain XSS and CSRF clearly with flow.